기술·사업 타당성 실증 제안

oneM2M
양방향 보안 게이트웨이

통신의 신뢰도와 장치 상태를 연결하는
실행 전 안전 정책 서비스

공통 허브
HTTP / MQTT

안전 정책
장치별 실행 조건

실증 플랫폼
도어락·난방 모형

2026.09.22 | Mobius4 기반 16주 MVP 제안

인증된 요청도, 위험한 동작으로 이어질 수 있다

기기의 데이터와 서버의 제어가 서로 영향을 주는 전체 흐름을 보호한다.

01 기기 → 서버

신뢰하기 어려운 입력

요청 폭주·사칭
오래된 데이터·센서 오류

02 서버 → 기기

현재 조건에 맞지 않는 제어

허용 계정의 오조작
상태·순서·범위 위반

03 기기 → 외부

피해를 확산하는 통신

허용 밖 목적지 접근
다른 장치로 횡적 이동

판단 기준: “누가 보냈는가”에 더해 “지금 실행해도 되는가”

제품은 공통 허브와 정책 서비스, 키트는 검증 수단

우선 고객: oneM2M 운영기관 · 시설 IoT 사업자 · 시스템 통합 사업자

제품 구성	16주 MVP 결과물	보호 경계
현장 허브	HTTP/MQTT 공통 요청 검사	허브를 경유하는 트래픽
정책 서비스	상태·신선도·명령 조건 / 버전 관리	정의한 프로필과 실행 어댑터
운영 화면	차단 이유·사건 이력·격리와 복구	역할별 권한과 감사 기록
실증 키트	도어락·난방 저전압 모형 2종	상용 설비 인증과 별도

전 장치 자동 호환·허브 밖 통신 보호·물리 안전 보장은 범위에 포함하지 않는다.

기존 보안을 제대로 구성하고, 실행 조건을 더한다

재사용

oneM2M / Mobius4

인증·TLS·ACP
자원 관리·구독·알림
배포 설정 검증

통합

네트워크 / IPS

망 분리·목적지 제한
알려진 공격 규칙
경보와 격리 연계

자체 개발

장치 의미 / 상태 정책

신뢰 상태·명령 전제조건
실행 직전 재검증
이유·정책 버전 기록

보안 연결과 접근 권한을 유지한 채, 업무·장치별 조건을 추가한다.

신뢰할 수 있는 종단과 실제 실행 직전에 집행한다

왕복 통신의 공통 경로를 확보하고, 현장 상태를 마지막에 다시 확인한다.

IoT 장치
센서 / 구동기

↔

현장 관문
망 분리 / IPS

↔

Mobius4 + 정책
인증·권한·의미

↔

서버·업무 앱
데이터 활용 / 제어 생성

현장 실행 가드
만료·중복·현재 상태를 확인한 후 실행

정책·감사·관리 서비스
버전 배포 / 상관관계 ID / 경보 / 격리·복구

TLS는 승인된 종단에서 해석 · 우회 경로 통제 · 기기 자체 안전장치는 유지

상향 보호는 서버 가용성과 입력 신뢰도를 함께 다룬다

위협·오류	판단 기준	처리
요청 폭주	장치·테넌트·작업별 할당량	초과 제한 / 다른 장치 처리량 확보
사칭·자원 오용	인증 주체와 허용 자원 매핑	권한 밖 요청 거부
형식·크기 오류	스키마·타입·단위·본문 크기	처리 전 거부 / 원인 기록
오래됨·위조 의심	시각·변화율·독립 센서·상태	신뢰 상태 표시 / 제어 입력 제한

실제 비상일 수 있는 센서 급변: 원본과 경보는 보존하고, 제어 판단을 분리한다.

하향 보호는 권한 확인 이후에도 판단을 이어간다

CSE 자원 저장 성공과 실제 기기 동작 성공을 구분한다.

1
권한
신원·접근 권한

→

2
명령
단위·범위·버전

→

3
상태
순서·인터록

→

4
근거
신뢰·신선도

→

5
실행
만료·중복

장애 시 기본 동작과 비상 경로는 장치별로 정의한다. 일괄 허용·차단하지 않는다.

최종 실행 가드가 상태를 다시 확인하고, 판단 결과와 실제 실행 결과를 각각 기록한다.

상향 데이터의 신뢰 상태가 하향 제어 조건이 된다

같은 사건 ID로 센서 입력부터 실제 동작까지 연결한다.

01

센서 입력

오래된 값 또는
급격한 변화

02

신뢰 상태

신뢰 → 불확실
시각·근거 기록

03

서버 판단

자동제어 요청
생성

04

실행 조건

UNTRUSTED_INPUT
위험 동작 제한

함께 확인할 결과: 위험 동작 미실행 + 정상 요청 통과 + 실제 비상 경보 보존

검증 가설: 데이터 신뢰와 실행 조건의 연결이 IPS 단독 구성보다 추가 효과를 만든다.

HTTP와 MQTT의 공통 경로에서 일관되게 검사한다

기준: v4.24.5 · 3da4d852… | 배포 전 업스트림 변경 재검토

위치	추가 연결점
HTTP / MQTT 바인딩	파싱 전 본문 상한 / 인증 주체를 장치·테넌트와 연결
reqPrim 유입·원격 전달 전	장치별 할당량·목적지 정책
로컬 ACP 이후·부작용 전	자원·명령 의미·현재 상태 정책
그룹 / 알림 / 장치 어댑터	구성원 검사·목적지 제한·최종 실행 재검증

X-M2M-Origin 헤더만으로 장치 신원을 신뢰하지 않는다.

운영자는 “왜 제한됐고 무엇을 해야 하는지”부터 본다

제어 제한 · 난방 모형 01

**상태 정보가 오래되어
설정 변경을 보류했습니다.**

영향: 설정 변경만 제한, 위험 경보 유지
확인: 센서 연결 → 상태 갱신 → 복구 검사

정책 운영 흐름

재생 검사 → 관찰 모드
담당자 승인 → 제한 적용
효과 확인 → 확대 / 롤백

정책 버전·이유 코드·실행 결과 기록

모형 키트는 동작 결과까지 재현하는 테스트베드다

실제 잠금장치·연료 계통에 연결하기 전에 저전압 모형에서 검증한다.

항목	도어락 모형	난방 모형
입력·출력	문 센서·상태 스위치 / 서보·LED	온도 시뮬레이터·인터록 / 팬·LED
정상 시연	권한과 상태에 맞는 잠금·해제	신선한 입력에 따른 설정 변경
공격·오류	중복 해제·자원 오용·폭주	위조 의심·오래된 상태·범위 위반
확인 증거	모형 실행 횟수 + 판단 로그	위험 미실행 + 경보 보존

키트 판매는 실증 이후 별도 판단. 핵심 사업 자산은 재사용 가능한 정책과 운영 도구다.

유사 기능은 이미 있다. 추가 가치를 비교해야 한다

차별화 가설: oneM2M 자원·장치 상태·센서 신뢰를 묶는 통합과 운영 편의

대안	공개된 기능	우리의 비교 과제
Suricata / Fortinet	MQTT 검사 / OT 명령·값 차단	상태·신뢰 연계의 추가 효과
Nozomi Guardian	수동 탐지 + 방화벽 연동	실행 전 집행·대응 지연
Firewalla DAP	행동 학습·허용 목적지 제한	장치 의미·정책 관리 편의
AWS IoT	보안 감사·행동 탐지·완화	현장 가드와의 역할 차이

AWS Detect: 2026.08.31부터 신규 고객 제공 종료. 기존 고객 유지 / Audit 영향 없음.

구매 의사는 고객의 실제 운영 문제에서 확인한다

대상 시장 규모와 유료 고객 수는 아직 검증되지 않았다.

10곳 인터뷰

문제·구매자 확인

장애·정책 변경 시간
기존 대안·예산·결재자

2개 현장 후보

연동 조건 확인

TLS·장치 API·우회 경로
지원 범위와 책임 경계

유료 파일럿

반복 판매 가능성

지불 의사·지원 시간
두 번째 현장의 통합 비용

데모 반응·탐지율만으로 시장성을 주장하지 않는다. 비용과 구매 의사를 함께 검증한다.

가격은 실증으로 검증할 가정이다

VAT 별도. 아래 값은 계약·판매 실적이나 확정 견적이 아니다.

항목	매출 가정	직접원가 가정	매출총이익
사이트 최초 구축	300만 원	180만 원	120만 원 / 40%
월 서비스 / 사이트	50만 원	25만 원	25만 원 / 50%
첫 12개월 합계	900만 원	480만 원	420만 원 / 46.7%

월 직접원가 15만 / 25만 / 35만 원 → 총이익률 70% / 50% / 30%

연구개발·영업·관리·세금 제외. 영업이익률 또는 순이익률이 아니다.

인접 기업 실적을 우리 제품 마진으로 바꾸지 않는다

기업	매출	수익성 지표	판매·규모 해석
Verisure	€3,745.4m	조정 EBIT 마진 25.4%	연말 약 620만 고객 Q4 신규 설치 22.4만
Allegion	US$4,067.3m	GAAP 영업이익률 21.1%	개별 스마트락 수량·마진 미확인
Resideo	US$7,472m	매출총이익률 29.4% 영업이익률 8.12%*	개별 보일러 보안 키트 수량·마진 미확인

* 607 ÷ 7,472로 계산. Resideo GAAP 순손실 US$527m. m = 백만.

oneM2M·안전·AI의 조합만으로 신규성을 주장하지 않는다

대표 문헌	중첩 가능 영역	검토 방향
KR102863685B1	oneM2M 변환·현장 AI·선택 전송	가장 가까운 개념: 독립항 대조
KR102889055B1	IoT 라우터 이상 감시 모델 할당	관찰·학습 계층의 구성 구별
KR102419687B1	PCA 기반 IoT 이상 탐지	탐지 기법 자체의 선행성
US11616795B2	통신 통계 이미지·persona	데이터 변환·판정 절차 비교

검토 후보: 신뢰 상태의 제어 연계 · 검사–실행 간 상태 일관성 · 공통 경로 집행

같은 환경에서 A → B → C의 추가 효과를 측정한다

서버 응답과 실제 모형 실행 여부를 따로 관찰한다.

A 기준선

기본 oneM2M 보안

인증·TLS·ACP
Mobius4 정상 보안 설정

B 일반 보호

A + 네트워크 / IPS

망 분리·목적지 제한
Suricata 검사·차단

C 제안 구성

B + 의미 / 상태 정책

입력 신뢰·실행 조건
현장 가드·연결된 감사

비교 축: 위험 동작 · 오차단 · 경보 보존 · p95 지연 · 운영 시간

합격 목표는 차단률과 운영 부작용을 함께 본다

합성 시험 결과를 실제 현장의 전체 공격 탐지율로 홍보하지 않는다.

항목	합격 목표 / 관찰값
위험 동작	지정 치명·우회·재실행 시나리오의 실제 위험 동작 0회
공격·오류 200건 이상	사전 정의한 차단 대상의 차단률 ≥ 95%
정상 요청 10,000건 이상	오차단률 ≤ 0.1% / 오류·비상 경보 적정 처리 별도
추가 지연	100장치·100요청/초: p95(C) − p95(B) ≤ 20ms
장애·경로 일관성	HTTP/MQTT·그룹·전달·알림·단절·재시작 시험

16주 동안 구현보다 먼저 범위와 검증 조건을 고정한다

전제: 4인 팀, 장치 API와 시험 환경을 2주 안에 확보

1–2주
범위·고객
위협 모델 / 프로필

3–5주
공통 경로
신원 매핑 / IPS

6–8주
정책·실행
신뢰 상태 / 가드

9–11주
시연·운영
키트 / 감사·알림

12–14주
비교 검증
A/B/C / 장애·부하

15–16주
고객 실증
지원 비용 / 판단

2주: 문제 확인 / 8주: 집행 가능 / 14주: 효과·부작용 / 16주: 지불 의사

4인·16주 MVP의 계획 예산은 1억 560만 원이다

VAT 제외. 공급업체 견적·실구매 부품 가격이 아니다.

항목	산정 기준	금액
인건비	4명 × 4개월 × 500만 원	8,000만 원
시험 장비·키트	계획 배정 / 상세 견적 추후	600만 원
환경·외부 검토·실증	호스팅 200 + 외부 검토 800	1,000만 원
예비비	소계 9,600만 원의 10%	960만 원

보안 리드 · 플랫폼 개발 · 네트워크/IoT 개발 · 화면/QA 개발

특허의 문헌·출원인·기술 범위를 나누어 읽는다

등록 문헌	최초 출원인	독립항 검토 초점
KR102863685B1	에즈웰	oneM2M·현장 AI·선택 전송
KR102889055B1	케이티	라우터별 이상 감시 모델 할당
KR102419687B1	숭실대 산학협력단	PCA 투영과 거리 기반 탐지
US11616795B2	McAfee LLC	통신 통계 이미지·장치 persona
US10629037B2	IBM Corp.	케이스 내부 광량 변화·침입 알림

표준·소스·공급업체 문서는 서로 다른 증거다

전체 URL은 각 슬라이드의 발표자 노트에 수록. 확인일 2026.09.22

근거	문서 / 확인 범위
[S01] [S18] Mobius4	v4.24.5·3da4d852… / 요청 경로·TLS·설정
[S02] [S03] oneM2M	Developer Guide / TS-0002 보안 요구사항
[S04] [S05] Suricata	8.0.4 IPS concept / MQTT 검사 키워드
[S19] oneM2M 연동	TS-0040 Modbus / 외부 작업·자원 갱신 조율

표준 요구사항 ≠ 배포에서 활성화된 기능 ≠ 실제 안전성 검증 결과

시장 사실·사업 가정·미확인 항목을 분리한다

구분	자료 / 사용 원칙
경쟁 기능 [S06–08, S20]	AWS·Fortinet·Nozomi·Firewalla의 공개 기능
공시 [S09–11]	FY2025 전사 실적 / 제품별 수량·마진과 구분
배경 연구 [S12]	2020년 IoT 보안 문헌조사 / 현재 비율로 확대 금지
계획·미확인	예산·가격·성능은 목표 / 시장 규모·지불 의사 미검증

특정 제품의 부재를 확인하지 못했다고 시장 공백·신규성이 입증되는 것은 아니다.

16주 MVP로 “추가 보안 효과와 고객 가치”를 입증한다

핵심: oneM2M 공통 허브 + 장치별 안전 정책 / 키트는 재현 가능한 실증 플랫폼

기술 근거

실행 결과로 입증

A/B/C 비교
위험 동작·오차단·지연

운영 근거

반복 적용을 입증

두 장치 프로필
정책 배포·감사·복구

사업 근거

구매 이유를 입증

고객 실증·지불 의사
통합·지원 원가

착수 범위: 4인 · 16주 · 1억 560만 원의 계획 예산 / 2·8·14·16주 단계 평가